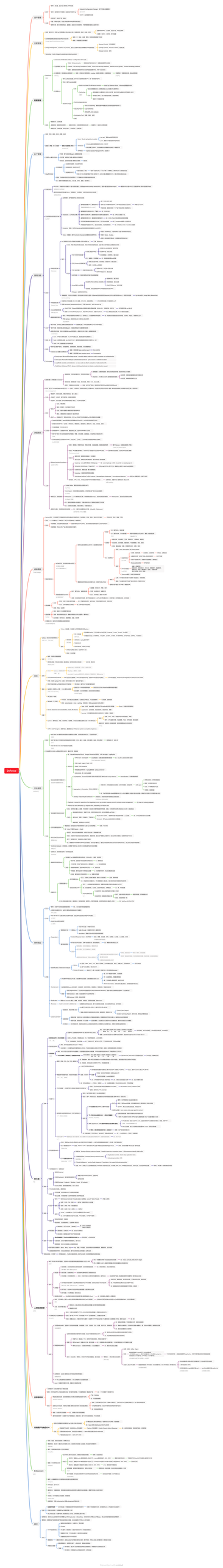

Defence

资产管理

- 库存
  - 硬件：含U盘、盘点 by 条形码 / RFID标签
  - 软件：保护软件许可密钥 + 检测无许可软件 by
    - Endpoint Configuration Manager：资产管理+配置管理（曾 SCCM）
    - SCOM：监控健康和性能
  - 无形资产：知识产权、商标…
- 介质
  - U盘：采购大品牌，如金士顿自带IronKey保护/身份验证
  - 磁带介质：新介质密封包装、温湿度、适应24小时后使用、不使用暴露在磁场尘埃的介质

变更管理

- 流程：提交RFC - 审查 by 变更经理(小变)/CAB(大变) - 批准/拒绝 - 测试 - 实施 - 记录
  - 变更申请书RFC：含请求、回滚计划、审批记录等
  - 小变更：如补丁、改DNS、帐号创建
- 变更 管理/控制/咨询委员会CMB/CCB/CAB（Change Mgnt/Control/Advisory Board）
  - 成员：IT、安全、法律、管理、财务和采购等部门代表
  - 职责：审查变更及例外请求
- Change Management：Guidance on process，部分企业据ISO安全保障要求(SAR)量制规定
  - Request Control：优先级排序
  - Change Control：Process in action，权限分配
  - Release Control：发布
- Versioning：track changes by labeling/numbering system

配置管理

- Baselining 基线
  - composed of individual settings = configuration items (CI)
  - 1. 选择基线 by 参考
    - 行业：CIS benchmarks —— 控制目标评估工具CSAT：检查加固是否符合基线
    - Vendor：MS Security Compliance Toolkit、Azure Linux security baselines、RedHat security guides、VMware hardening guidelines
    - 国防：国防信息系统局DISA 安全技术实施指南STIGs、NIST checklists
  - 2. 按需定制：修改基线以适用组织 —— 包括：识别/设计常用控制 - scoping - 选择补偿控制 - 分配控制值 —— 范围界定：审查控制列表 - 筛选适用控制（tailoring / scoping）
  - 3. 部署 by
    - 部署/工具自动配置，如Windows组策略对象GPO - 统一管理域中的PC
    - 手动：基于checklist配置
    - Baseline Image
      - OS
        - build on a clean OS with secure version —— install by 如Norton Ghost、Windows部署服务WDS
        - Hardening 加固
          - OS
            - 验证系统配置(Win-注册表设置/Linux-配置文件)是否符合
            - 禁用/删除不必要的软件、服务、端口等：通过主机FW限制访问开放服务、端口
            - 禁用默认帐号：最小化管理员权限；强密码策略
            - 最新补丁和漏洞修复
      - Runtime dependencies
      - Security Tool
        - Auto vul scanning：确保闲置VM被重启时及时发现漏洞并获得补丁
        - Log monitoring
        - HIDS/HIPS、Anti-malware
      - Automation Tool：配置、备份、监控
      - IAM
- 流程
  - 配置标识：记录配置
  - 配置控制：配置更新经授权 —— 配置状态统计：跟踪授权更改的过程 —— 配置审计：确保无未授权配置
  - 配置文档：当前配置、系统负责人、系统目标、变更记录

补丁管理

- 流程：评估 - 测试 - 批准 - 部署 - 验证
- 自动 vs 手动：快 vs 精准 —— 更新/ 快速修复/ 热补丁（quick-fixe fix）
  - Linux：#sudo apt-get/yum update
    - apt-get：更新deb格式的软件包
    - yum：更新rpm格式的软件包并安装
  - Windows
    - Windows服务器更新服务WSUS：热补丁
    - 微软部署工具MDT：使用镜像自动部署服务器/桌面 + 配置管理
  - VMWare —— vSphere Update Manager(VUM)：自动补丁
- 分散式 vs 集中式(MS)
  - 代理：每个设备安装agent-连接到服务器
  - 无代理：域控等中心设备-使用动态目录更新
  - 被动式：监视网络流量-推断是否更新 —— 最无效
- 0day零日攻击
  - 时间差类型
    - 攻击者发现漏洞 - 供应商不知情
    - 供应商知情 - 尚未发布补丁
    - 供应商发布补丁
      - 组织先测试 - 再打 —— "组织一直未打补丁 + 大于n周 + 不算零日，算对未打补丁系统的攻击"
      - 周二补丁日 (MS每月第2个周二发布补丁) - 逆向工程 (需查解析补丁) - 周三利用日(发动攻击)
  - 策略：CVE和IDS签名无法及时更新 》手工收集信息 识别缓解措施和临时补丁
  - 防：禁用不需要的服务/协议、防火墙、IDPS、蜜罐、填充单元

漏洞扫描

- 标准/法规
  - PCI DSS：季度的内外部漏扫 + 重大变更后漏扫，使用approved scanning vendor(ASV)，整改+重扫直至clean report —— 漏洞CVSS分值>=4.0 》扫描结果Fail (有补偿控制可Pass)（适用信用卡业务企业）
  - 联邦信息安全管理法案FISMA：定期漏扫，分析整改，与其它政府机构分享结果（适用政府机构）
- 安全内容自动化协议SCAP by NIST
  - 应用场景：资产漏洞评估 | 系统安全合规
  - Standards：公开标准(元素)
    - 通用漏洞披露CVE：漏洞的编号（国家漏洞数据库NVD by NIST）
      - 如：CVE-2021-1001
      - 签发 by CVE编号机构CNA：100+供应商,安全公司,机构 —— 申请 by anyone
      - 判定依据：漏洞只影响一个产品 可独立修复 供应商承认
    - 通用漏洞评分系统CVSS：严重性 —— 如：CVSS:3.0/…
    - 通用平台枚举CPE(元素)：漏洞影响的OS/软件/设备的编号 —— 如：CPE:2.3:类型:厂商…
    - 通用配置枚举CCE：基线配置问题的编号 —— 如：CCE-27868-9应设置恰当的密码策略
    - 可扩展配置检查表描述格式XCCDF：定义安全检查表 —— 如：heartbleed漏洞 > 检查项123
    - 开放漏洞评估语言OVAL：定义如何测试、检查检测措施 —— 如：存在libssl 1.0.0 > heartbleed漏洞
  - Contents：策略 = 为符合Standards的检测规则和修复脚本(Ξ+xml文件)
  - Tools：扫描器 = 基于Contents+Standards收集系统信息并评估
    - 开源：OSCAP(CL)、OpenSCAP scap-workbench(GUI)…
    - 商用：Nesus、Qualys…
    - 扩展：脚本检查引擎SCE：使用脚本编写安全内容
- 类型
  - 网络发现扫描 Discovery
    - for 发现存活主机+开放端口和服务+主机OS信息 by —— 工具：免费nmap
    - by
      - 端口
        - 状态：开放=有应用与端口连接、关闭=可用但无应用连接、过滤=防火墙干扰无法确定端口状态
        - TCP SYN半开放扫描
          - 向端口发送SYN
            - 收到SYN+ACK响应包：端口开放
            - 收到RST包：端口关闭
            - 未收到响应：主机存在、端口过滤
          - 优：速度快、行踪隐蔽 —— 劣：构造数据包需root权限
        - TCP Connect全连接扫描
          - 向端口发送SYN包 > 对方响应 > 回复ACK > 建立连接
          - 适用：未获得root权限时
        - TCP ACK扫描 —— 向端口发送ACK包
          - 收到RST包：未过滤=无防火墙
          - ICMP不可达error：端口过滤
        - UDP扫描 —— 扫描仅使用UDP端口的远程服务
        - Xmas扫描 | null扫描
          - 发送FIN+PSH+URG包 | 无标志包
            - 收到RST包：端口关闭
            - 未收到响应：端口开放
            - ICMP不可达error：端口过滤
          - 更隐蔽、但仅适用支持RFC793规范的目标(如UNIX)
        - FIN scan：长字符串909090…
      - "横幅提取：与目标主机通信 - 初次连接时主机默认返回一段banner信息(如服务为Apache,版本2.4,操作系统Linux…) - 获取目标信息 —— by netcat命令, nmap, Nikto, BannerGrab（banner grabbing）
  - 网络漏洞扫描 Network Vuln
    - 扫描页面+开放服务器+DB+OS+容器，如TLS1.0、弱加密算法 —— 多为非授权扫描+CVE漏洞库 via IP
    - 开源 Nessus(win)、Nexpose(win/linux)、开源 OpenVAS、WiFi Aircrack-ng
  - Web应用漏洞扫描 Web App Vul
    - +DAST工具，扫Web应用服务器+应用框架/漏洞/逻辑配置，如SQL注入、恶意代码、弱口令 —— 多为授权扫描 via URL/IP
    - 开源 Acunetix(AWVS)/Appscan、开源 Nikto/Wapiti、代理 BurpSuite —— 输入表攻击测试工具：Fuzzer提供攻击输入
  - 数据库漏洞扫描
    - 演化：Web应用程序访问DB的入口，如SQL注入 》扫描DB和Web应用 —— 如：检测动态页面的get/post参数、cookie、http头 》检查SQL注入
    - 开源 sqlmap - 自动化SQL注入工具 via URL(扫IP)（无法扫描DB）
- 方式
  - 基于网络：在网络上部署扫描器连接设备 —— 扫描器位置 》不同扫描结果 by FW、IDS/IPS规则
  - 基于代理：在要扫描的主机上安装agent - 扫描结果发送中央漏洞管理服务
  - 授权/无授权扫描：目标主机提供ID+pw(非管理员) > 登录主机深入扫描 + 读取配置信息（credentialed）
- 对象 - 云
  - IaaS：VM的OS,服务,服务 - by SCAP扫描工具，底层配置(网络,数据库…)
  - PaaS：应用系统,容器 - by OWASP ZAP，服务配置(数据库,网关,存储…)，API
  - SaaS：API，数据泄露/访问控制检测
- 结果
  - 排序 by 漏洞严重性、系统重要性、信息敏感性、整改难度、系统暴露程度
  - Validate by 配置/日志等信息
    - 误报：假性正面 false positive report —— true positive
    - 漏报：假性负面 false negative report —— true negative
- Vuls sample
  - ProxyLogon Microsoft Exchange server - remotely deploy malicious code to complete user authentication
  - ZeroLogon Microsoft's Netlogon authentication protocol - get access to a website's location
  - Log4Shell: remotely control device - run Java code on other's computer or leak sensitive info
  - PetitPotam: Windows NTLM - allows a LAN-based attacker to initiate an authentication request

渗透测试

- 漏洞扫描 + 了解功能 + 人为攻击
  - 道德黑客：无恶意的黑客，仅在授权后测试
    - 道德披露：发现漏洞 - 首先告知供应商修复 - 限定时间后公开漏洞
    - 赏金项目：多与第三方合作 - 提供漏洞跟踪报告
      - 全托管：对收到的漏洞报告进行完整分析
      - 半托管：将漏洞报告移交企业
  - 测试内容：漏洞扫描 + 攻击、端口扫描、嗅探、DoS、社会工程…
  - 授权：书面批准+安排时间 —— 风险：破坏生产系统、测试优先模拟测试(但无法保证prod)
- ROE：定义PT scope和approach的文档（rules of engagement） —— 流程：计划/目标 - 发现阶段(如无人机+WiFi) - 攻击阶段 (获权访问目标 - 提权 - 横向查找新系统 - 安装额外工具) - 报告阶段
- 分类
  - 黑盒PT：0知识/信息，模拟外部攻击，输入+输出
  - 白盒PT：全知识，基于源代码，检查内部逻辑
  - 灰盒PT：部分信息 / 源代码辅助检查输入输出，不分析内部逻辑
- 演练
  - 队伍
    - 红队：模拟黑客
    - 蓝队：防御方 - 大多演练中为夺手
    - 白队：裁判+跟踪防+确保演练不影响PROD
    - 紫队：演练结束后 红蓝队聚一起分享知识
  - 形式 —— 夺旗赛CTF：事先设定目标 - 评分 by 红队攻下的目标数 vs 蓝队防御的目标数量
- 方法论
  - OWASP测试指南：Web漏洞攻击安全测试指南WSTG(MSTG、IoT中间件安全测试方法论)
  - 渗透执行标准PTES：七阶段 - 事先交互、情报收集、威胁建模、漏洞分析、攻击、后攻击、报告
  - PCI渗透指南：PCI DSS #11.3
  - 渗透框架PTF：全面指导手册、覆盖测试工具、是SP AS400等的门扫标
  - NIST SP 800-115 信息安全测试和评估指南：审查、目标发现、漏洞验证、安全评估计划和执行等（2008）
  - 开源安全测试方法手册OSSTMM：安全分析、工作流、人为/物理/无线/通信/网络安全测试（by ISECOM）
- 工具
  - Network protocol analyzer（packet sniffer）
    - 别称：嗅探器、网络评估器、网络分析器、流量监视器、数据包捕获程序 —— 基于libpcap - 包捕获函数库 (开源)（Library for packet capture）
    - 前提：NIC配置"混杂模式" + 允许所有入站流量+无论目标MAC地址 —— 混杂模式无效原因：交换机未开启端口镜像（Promiscuous mode）
    - 功能
      - 捕获过滤：捕获哪些数据包、丢弃哪些
      - 显示过滤：按需实时展示数据帧 > 显示原始包 / 重组数据
    - 工具
      - tcpdump：Linux自带 抓日志 可生成.pcap —— 如：sudo tcpdump -i eth0 -nn port22 -w sample.pcap &
      - Wireshark、NetWitness、T-Sight/ZAP —— 分析.pcap文件 for 用户行为 - 数据包头,载荷 + NetFlow检测指标
      - Cain&Abel：捕获流量 - 暴力破解密码
      - tcpreplay：编辑/回放抓到的流量包
      - SolarWinds NetFlow Traffic Analyzer、ManageEngine OpManager、Azure Network Watcher —— 检测 for 流量性能 - IP,端口,协议…
    - 防嗅探：VPN、补丁、IDS无法识别MIMM可否警报常活动 —— 业务填充：流量中嵌入虚假信息 > 阻止分析（traffic padding）
  - 模拟红队：发现漏洞
    - Cobalt Strike：模拟真实攻击(含高级/APT)（by Fortra）
    - Core Impact：复杂的基础设施测试、识别网络/客户端/Web应用漏洞（by Fortra）
    - Metasploit：上千个漏洞利用工具、网络发现(结合nmap)、自动化测试的元模块（by Rapid7 开源） —— Meterpreter：溢出成功后的攻击模块
    - 优：提供扩展框架+自创漏洞、可通过操作/社会工程测试流程的工作机制
    - 劣：仅发现已知漏洞、现时仍侵犯、可能引发DoS
  - 模拟红队：持续性验证安全控制 —— 如：入侵与攻击模拟BAS工具、AttackIQ、Safebreach（基于MITRE ATT&CK模型）

威胁情报

Threat Intellige…

- Gartner定义：对信息资产所面临的现有/潜在威胁的可靠证知识，包括情境、机制、指标、推论与可行建议 —— 评估标准：及时、准确、可靠
- 目的：一个节点遭攻击 - 共享信息 - 其它节点迅速响应 > 智能防御
- 类型
  - 开源情报：从免费网站收集信息 —— 信息共享和分析中心ISAC：各行各有的非盈利组织 by 竞争对手合作
  - 闭源情报：专业公司+产品+具体信息(如可疑IP)
- 情报共享指标
  - MITRE系列：自动指标共享AIS项目（DHS国土安全部、NCCIC国家网络中心）
    - 结构化威胁信息表达式STIX：描述属性的格式
      - 开源
        - 1.0：基于XML，8域对象
        - 2.1：基于JSON，12+6域对象（2020） —— 网络可观察表达式CybOX：属性 / 威胁指标库（已集成至STIX）
      - 元模型
        - 威胁主体、攻击模式、工具、恶意软件、入侵集合、脆弱性
        - 攻击目标、应对措施、威胁指标、可观测数据、身份、报告
        - 分机、基础设施、位置、恶意软件分析、注释、意见
      - 如：攻击模式
        - 字段：name, description, kill_chain_phases
        - 类型
          - 攻击杀伤链（by Lockh…）
            - 1.侦察：信息收集 —— 2.武器化：工具研发 —— 3.传送：工具投放
            - 4.脆弱性利用：如用户点击+启动恶意软件 —— 5.后门安装
            - 6.命令与控制C&C：恶意软件回跳黑客 - 请求指示
            - 7.Execute攻击目标 —— 8.Maintain
          - ATT&CK模型（by MITRE） —— 侦察 - 资源开发 - 初始访问 - (命令)执行 - 持久化 - 权限提升 - 逃避防御 - 获取凭证 - 发现 - 横向移动 - (信息,凭据)收集 - 命令与控制 - 渗透 - 影响
          - "Diamond模型：专用于想要是升措
    - 情报信息的可信自动化交换TAXII：交换STIX的协议
      - 服务
        - 汇聚：TAXII服务器与客户端请求-响应通信 > 收集情报
        - 通道：TAXII服务器 作为客户端之间发布-订阅的中转站
      - 逻辑分组+通信 via API根 + 情报的URL
  - 开放威胁指标OpenIOC（by MANDIANT）
    - IOC：基于XML、威胁指标
      - 元数据：IOC名字、作者、简介
      - 引用：IOC的标识，如事件号
      - 定义：IOC内容、逻辑+"&/OR"
    - 流程：收集初始审慎信息 - 基于特征创建IOC - (HIPS,SIEM等)登记IOC - 发现可疑 - 保存收集证据 - 分析数据
- 威胁调查
  - 方式
    - 声誉：为每个IP地址分配声誉评级 —— 如：打着有名的IP、邮件地址、已知恶意软件哈希、共享代码
    - 行为：分析对象的行为模式 —— 如：识别活动与攻击相匹配
  - 资源：网站、论坛等
- 威胁狩猎（hunting）
  - 演化：被动 》主动搜索可能攻击
  - 流程：假设黑客攻击起步 - 搜集异常指标IOC(流量,文件类型) - 事件响应
  - 抑点供给：SIEM日志、威胁情报、流量、报告等
- 反情报欺诈（counterIntelligence）：阻止对手获取情报或散布误导情报

日志

- syslog：定义日志格式的协议（UDP 514、TCP 6514）
  - "Linux、路由器、无线接入点等网络设备支持syslog
  - 组成
    - HEADER
      - PRI：优先级
        - 程序模块Facility：日志来源 by 24位代码，0=kernel、1=user、2=mail … 23=预留
        - 严重性Severity：0=EMERG、1=ALERT、2=CRIT、3=ERR、4=WARNING、5=NOTICE、6=INFO、7=DEBUG
      - VERSION：syslog版本号"1"
      - TIMESTAMP
      - HOSTNAME：FQDN / IP地址
    - STRUCTURED-DATA：ELEMENT + ID
    - MSG：日志内容
- 分析
  - 抽样：有意义的数据提取（sampling）
  - 剪切级/阈值：预先设定阈值 - 建立基线 - 如失败登录5次后记录 —— 成本低、易实现（clipping level）
- 实现
  - Linux —— Syslog：日志为UDP（1980）
    - syslog-ng：+可扩展过滤、+TLS、+UDP+TCP
    - Rsyslog：+模块、+查询
    - journalctl：systemd程序日志记+二进制日志、兼容syslog
  - Linux/Windows/Android —— NXLog日志处理系统：win本身不支持syslog - 封装eventlog至syslog格式 —— "eventlog类型：info/error/warning/failure adults/success audits
  - 作用：关联 <syslog+TLS> 工具 - SIEM方案 》跟进行为审查
- 安全
  - 同步可信时间源 by 网络时间协议NTP服务器 —— 举行验证：基于日志"时间戳"重构事件
  - WORM一次写入多读：日志文件 + 中央系统接收数据 —— 防日志改变 by PowerShell脚本根据外备份（write once read many）
  - 日志截断：日志发给中央服务器 - 旧日志被删除
  - 单工通道 + 加密
- 对象
  - Network：IP、MAC…
    - Firewall：允许/阻止的流量信息、记录包头(IP/端口)、不记载数据 —— TLS加解、加密损值
    - DNS：zone transfer、error、caching、DNSSEC、DNS queries(含来源IP)以关注
  - Server related to services(websites, emails, file shares)
    - Web：状态、Web请求 + 利用HTTP method此状态,浏览器… —— Proxy：如请访问哪些网站
    - Application：应用启动、如启动状态、成功/失败、告警
    - Security：对关键资源的成功/失败的访问(如DB)
  - System：硬件变更、升级、时间同步、组策略、OS活动(如重启/服务关闭) = Win事件日志
    - 指标
      - 软件：CPU、内存、磁盘空间(IO读写速度)、网络
      - 硬件：CPU温度/负载、风扇速度、电压、时钟速度、驱动速度
    - 转储文件：进程第一时刻的快照，程序异常调试分析时使用（dump）
  - VoIP & Call Managers：话音内容、通话质量 by MOS(mean opinion score),jitter,signal loss

安全监控

monitoring

- 指南
  - NIST FIPS 200 联邦信息和信息系统最低安全要求：按需生成/保存日志、可追踪至用户（2006）
  - NIST SP 800-137 信息安全持续监控ISCM项目：定义 - 建立 - 实施 - 分析/报告 - 响应 - 审查/更新 —— 适用800-37、800-39（2011）
  - NIST SP 800-137A ISCM项目的评估指南（2020）
- 安全运营中心SOC vs 网络运营中心NOC：重点不同、有重叠
- 工具
  - 安全信息和事件管理SIEM（安全事件/信息管理SEM）
    - 如：Splunk Enterprise/Cloud、Google Chronicle(云原生)、HPE ArcSight、LogRhythm
    - Source
      - VM in IaaS - local agent —— 云应用监控：收集云服务器的原始数据 —— 如：云上导入(生日志收集器+延时)（Cloud Application Security）
      - SQL in IaaS - agent / PaaS - API
      - IDaaS - API connector
      - 网络虚拟化的NVAs - Syslog服务器 - syslog connector
      - XDR,CASB - 同一CSP+直接传
    - 机制
      - Log Ingestion：Source 收集-解析-聚合-传递日志至 SIEM build-in log collector —— Normalization：标准化数据格式
      - Aggregation + Correlation：聚合+关联日志
        - 关联引擎：所有数据的日志分析 - 分析共同属性 - 发现异常 —— 分析 upon
          - 异常值/方式：异常的数据值
          - 趋势：时间段内的变化
          - 行为：不寻常的用户行为
          - 可用性：系统性能
        - 如：FW可疑流量+Web服务器SQL注入+DB大量查询+服务大量出站流量 > 单独日志无意义 但关联后 确认攻击
      - Alerting + Reporting & Dashboard —— 持续优化：持续评估事件发现模式/源的有效性（Continuous Optimization）
    - Playbook: a manual for operations from beginning to end, e.g. incident response, security reviews, access management… —— 如 chain of custody playbook
    - Metrics: Key tech attributes, e.g. response time, availability, and failure rate
  - 安全编排与自动化SOAR
    - 演化：SIEM需大量人工集成、开放接收门 》自动补充需求的IP等信息，补充SIEM(日志事) 供识别人工分析 + 自动响应
    - 功能
      - 安全编排与自动化：定制工作方式 - 识别打包自动化任务 - 执行应用程序+ACTION
      - 事件响应：告警、记录事件、工单流程 —— Playbook：一套事件识别+响应操作手册 - 人工实施；Runbook：用Playbook通过自动化工具实施 —— 如：SYN泛洪的识别+应对步骤
      - 威胁情报：多源整合+分析识别
  - 文件完整性监控FIM
    - 调查阈值 - 定时监控文件变更并+上报 by 比较哈希值 —— 标准：PCI DSS
    - 如：Linux 开源tripwire - check
  - 用户实体行为分析UEBA（安全行为UBA）
    - 原理：网站访问和网络数据 - 对用户活动分析 - 找潜在威胁
    - 如：发现用户帐户的异常活动/权限移增等 - 数据采集 - 建立用户画像基线 by 机器学习 + 定义正常行为 - 检测用户行为
    - 基于：高度数据日志、网络流量+机器学习
  - Sentiment analysis：识别情感、改善客户服务 by AI分析文本中的情感倾向（情绪分析）
  - 数据库活动监控DAM
    - 实时审计 for 检测数据库的活动，如SQL注入、提权、篡改等
    - 类型
      - 基于网：监控网络上的数据库流量 —— 优：不影响性能
      - 中间代理：在客户端和DB之间、透明监控 —— 劣：单点故障风险
      - 数据库审计：监控DB的所有活动 —— 劣：资源占用
      - 网络层：集中监控多个DB的流量 —— 劣：无法检测加密流量
      - 云端：集中监控+可自动扩展 —— 劣：依赖CSP服务
  - 流量分析
    - 1.复制流量 by
      - 端口镜像SPAN
        - 定义：交换机上的端口配置 - 源端口+目的端口 —— 适用：简单网络
        - 劣：非监视端口流量丢失、不工作数据包重发、端口速度快…
      - 测试访问接口TAP
        - 定义：一种硬件设备/软件 - 部署在网络设备之间,复制流量至监控设备
        - tapping部署
          - 主动式TAP：插入新设备开始串联中继 —— 期间连续性：把链接接断开
          - 被动式TAP —— 无线：无线信号收一收
    - 2. 传入网络流量分析器：通信信息 > 识别可疑流量 —— 如：NetFlow、sFLOW、IPFIX

事件响应

- 定义：事件：对OA有负面影响的事件 —— ITIL：一个已知中断或质量降低
  - 计算机安全事件定义：破坏计算机或网络安全的不良事件（RFC 2350）
- 参考
  - NIST SP 800-61 处理计算机安全事件指南：违反/即将违反安全策略/AUP的情况（v2 2012）
  - SANS 504-B 事件响应手册（v1 2019）
- 步骤
  - Preparation
    - 制定响应计划 - 演练 by
      - read-through：审阅checklist
      - walk-through：跟桌面演练
      - simulation：跟进训练+特定攻击场景的响应
    - 建立响应团队
      - Incident Response Team：24/7可用 —— 成员：高管、安全团、SME、法律团、公关、人力资源
      - IR Service Provider：IR Team的补充 —— 如：联调外部for取证工作
      - 类型
        - 虚拟团队
        - 永久团队
        - 混合
        - 计算机应急小组：CERT / CSIRT
  - Identification / Detection+Analysis
    - Alerts —— by 监控：SIEM、IDPS、FW、身份认证系统、文件完整性监控、漏洞扫描器…；by 客户/员工其他第三方举报
    - Primary IR Handler —— 安全员工+第一响应者 》迅速行动 + 初步调查和Detect
  - Containment
    - 评估事件严重性(低/中/高) - 确定事件响应级别 - 通知管理层/相关人员
      - 低：第一响应者可解决、无需加固
      - 中：启动IR团队、需通知管理层
      - 高：立即响应+通知高层、IR全员出动
      - FBI InfraGard计划：与执行部门建立联系、共享信息
    - 选择遏制策略 upon 是否破坏、证据保存、服务可用性、资源需求、预期效果、策略持续时间
    - 策略
      - 隔离 segmentation：在内网/DMZ创建新的VLAN(=Quarantine Network) - 受害者监视
      - 隔离 isolation：区别 - 仅连接隔离网络 + 不连内网/DMZ
      - 移除 removal：断网 - 攻击者无规
  - Eradication —— 根除root cause by 重启、重建、修漏洞、改配置、还原备份数据、删malware
  - Recovery —— back to normal + validation by —— 检查服务是否恢复正常、每个系统的安全配置、日志是否正常传送、帐号权限
  - Lesson Learned
    - 经验教训：抓紧开展一记忆
      - by 第三方(独立性)+主持人 + 事件涉及人员+参与者
      - 复盘+改进事件响应流程/安全控制 - 编制报告 - 更新IR计划
        - Lesson Learnt Report
        - Incident Summary Report：技术文档、各响应步骤的复盘
    - 证据保留
      - 收集证据：自愿交出 / 法院传票 / 申请搜查证 / 童搜搜令
      - 保护证据：保持持续，不关系统 —— 证据完整性：如远程在中央日志服务器、数字签名验证日志完整性
    - IOC生成 —— 执行根据分析 - 确定攻击指标IoA (损害指标IoC) - 采取补偿控制/监控新措施

防火墙

FW

- 发展
  - 静态包过滤FW /无状态检测（L3 1代）
    - 配置ACL 过滤数据包(Header by 源/目标IP、端口、协议)
      - ACL：操作 | 源IP | 目标IP | 协议 | 协议属性；allow 10.. 11.. tcp 80 any 如SYN —— 协议属性，如TCP控制位、UDP会话空闲时间、ICMP类型…
      - 配置：permit 协议名 host 源IP host 目标IP；如permit udp host 10.1.1.1 host 172.1.1.1
    - 实现 by FW设备、网络路由器、OS、特定网络服务、L3/4交换机
    - 优：过滤速度快、防IP欺骗 —— 劣：无身份认证、端口永久打开、不支持动态应用、不防DNS欺骗
  - 动态包过滤FW
    - 演化：静态包过滤端口永久打开 + 不安全
    - +动态端口：主机建立连接非通用端口(>1023) - FW动态创建ACL规则+打开端口 - 通信 - 结束后删除规则+关闭端口
  - 状态检测（L3/4）
    - 演化：ACL不足 - 无法识别TCP包连续，FTP自动获得使用ACL不了解应用协议工作方式
    - +状态化表项：跟踪会话、检查连接序列性 —— 状态化表格：协议 | 源IP | 源端口 | 目标IP | 目标端口 | 连接状态；tcp 10.. 90 11.. 80 ok —— 如SYN>SYN / ACK>ACK | 识别超时连接 —— DoS攻击：塞满会话表
  - 代理FW
    - 原理：终端 - TCP - FW - TCP - 服务器
      - 优：隐藏源IP、缓存+网页浏览更快+节省带宽、清洗流量(识别过滤非HTTP流量)
      - 劣：性能差、支持应用少(常用于HTTP)、终端配置代理
    - 电路层FW/电路代理：可提供伴网通信（L5/4 2代 无状态）
      - + 独立于应用协议的ALG
      - 实现：SOCKS
        - 双向通信的轻量级代理协议 (基于端口和IP)
        - 配置
          - 终端：SOCKS开发类库 - 标准Socket API
          - FW所在服务器：sockd伺服软件
          - v4：+FW转发TCP会话 + 跨L7协议 —— v5：+802.1x身份验证+UDP —— v6：减少v5握手次数
      - 优：所有应用协议 > 一个网关、非常快 —— 劣：过滤粒度粗、对UDP过滤=全或无、不防IP欺骗
    - TCP包装器：一种基于用户/系统ID 限制端口访问的FW
      - 目的：仅允许特定客户端访问服务器(Linux/UNIX) —— # inetadm -M tcp_wrappers=TRUE
      - 适用：保护SSH、FTP、sendmail
    - 应用层FW/应用级网关ALG：基于应用协议（L7 有状态/无状态）
      - 演化：NAT仅将IP+端口 》ALG将应用数据
      - 拓扑：用户 - 网关(认证) - 路由器(仅允许网关发起的连接 (源IP+ALG)) - 目标主机
      - 实现
        - Web应用防火墙(WAF)：防Web攻击
          - 形式
            - 硬件：位于网络FW-Web服务器之间
            - 软件：装在Web服务器 - 服务器附加组件 / 虚拟服务 / 系统过滤器
            - 云WAF：第三方云端过滤流量、尤其抗DoS
          - 过滤http流量：user, session, data, app-specific context
        - 下一代安全Web网关SWG：一种云订阅服务（NGSWG / NG-SWG）
          - 检查浏览器流量 - 阻断对恶意站点和内部的访问
          - = WAF +TLS加密 +CASB +ATP(沙盒,ML威胁检测) +DLP +流量元数据 +日志
        - XML Appliances：XML服务专用安全设备(硬件/虚拟)
          - XML防火墙：验证入站XML code、监控对系统XML加载的访问请求、限速、保护API
          - XML 加速器：独立于应用的设备处理XML code - 实现应用加速；部署：FW前或原服务器之间
        - API 网关：接口调用的反向代理 - 过滤请求 —— 部署：客户端和服务器之间
      - 优：颗粒度细、日志记录全、身份验证、抵御IP欺骗攻击 —— 劣：一种应用协议一个网关、性能有限
    - 内核代理FW —— 数据包进入内核模块 - 基于动态定制规则检测OSI 7层数据包（L7） —— 优：快于ALG
  - 多功能防FMFD
    - 演化：传统FW+IDS/IPS-防病毒+URL过滤代理-反垃圾邮件、+单行处理流量-数据包延迟、成本高、维护各种设备
    - 统一威胁管理UTM（适用小企业） —— 功能：NGFW + VPN + 合并(邮件,URL过滤+网络内容/恶意软件监控+DLP) —— 架构：各模块串行 > 影响性能
    - 下一代防火墙NGFW（适用大企业 L3/4/7）
      - 传统FW：Package filtering-malicious header、Stateful inspection-connection status、VPN awareness-identify VPN traffic
      - +深度包检测DPI：Package filtering-malicious body
        - +Application control：block risky application data
        - +Intrusion prevention = IPS
      - +Threat intelligence：receive feeds (signature, IP reputation..) to support Intrusion prevention
      - 功能：FW + 关联应用、NAT转代、流量可视、TLS卸载、IDPS、QoS、VPN路由、身份验证、邮件过滤、政府监控网络流量… —— 架构：单引擎 > 各模块集成+联动
  - "内网隔离FW：'完零信任'
- 架构
  - 网段
    - 因特网 internet
    - 外联网 extranet：连内部网和因特网
      - 屏蔽子网screened subnet：旧称DMZ
      - 合作伙伴网
    - 内联网 intranet：Endpoint、Wireless、Guest、DC network
    - Ad-hoc网络：临时搭建的网络，如个人热点
  - "FW无法区分物理 or 逻辑网络
  - 流量
    - 东西流量：特定网络/DC/云 内部的网络流量
    - 南北流量：内网服务器 与 因特网服务器 间的网络流量
- 类型
  - 软件 —— 如Windows Defender Firewall (出站/入站策略)、Linux IP Table Firewall —— 开源 vs 专有
  - 方式
    - 硬件
      - 边界：外网 - FW - 内网 —— 一层FW：接收所有出入站流量
      - WAF：DMZ - FW - Web服务器
      - 内网：内网1 - FW - 内网2 —— 二层FW
    - 虚拟
      - VLAN：一台物理FW > 分多个FW逻辑实例 在VLAN间
      - 云：CSP内置的安全组/ACL功能、FWaaS服务、CSP的FW服务
  - 模式
    - 透明/网桥模式：性能高
    - 路由模式：负责路由转发、过滤策略-更安全
- 规则
  - 常见错误
    - 影子规则：设了 但没用（顺序错了） —— 如：allow 内 所有外；deny 内 特定外
    - 冗余规则：冗余访问 —— 如：allow 内 所有外
    - 孤立规则：服务器/服务下线了 但规则没删
  - 类型
    - 隐式拒绝规则：不允许未经授权系统访问FW —— 如：白名单
    - 沉默规则：忽略不需要的辅助数据包、减少日志
    - 清理规则：丢弃+记录未匹配上述规则的流量
  - 基于规则/代码操作：allow、deny、log —— log：流量、FW重启、启动失败的代理/依赖服务、配置更改、运行错误
  - 远程服务安全规则RTBH：在流法目的地前 - 基于源/目标地址丢弃流量 + 边界过滤
- "漏路由攻击：如 网络攻击者进入 + FW的OS直接转发 + 未经FW过滤 OS将路由常规数据包转发到外部

入侵检测防御

IDPS

- NIST SP 800-94 IDPS指南：主动IDS + 持续更新且监控内部的入站口 + IPS（2007）
  - IDS：可部署在网络中 + 攻击抵达目标前检测 —— 如：Cisco、Suricata、Zeek、Snort、Sagan
  - IPS：部署在入站口 + 捕获所有流量+在恶意流量抵达目标前拦截
- 技术
  - 特征型（基于知识/签名signature）
    - 规则匹配：已知攻击模式签名数据库 - 实时匹配数据包 —— 劣：库实时更新、无法识别新攻击
    - 模式匹配：数据包检查 —— 如识别IP拼接类型的漏洞
    - 状态匹配：状态跟踪序列 —— 状态：OS在可变/永久的内存位置的快照、操作活动 —— 如远程用户连接 - 发送数据 - 缓冲区被填写 缓冲区溢出攻击
  - 异常型（基于行为 / 启发 / 异常 anomaly —— *专家系统）
    - 对环境进行模型化 - 建立常态流量描述文件profile/基线 - 实时比对活动+状态告诉
      - 异常示例：激增流量、多次登录失败、正常时间外登录、错误消息
      - 优：可检测新攻击/零日攻击/少量APT攻击
      - 劣：建基线花时间+随网络配置不停更新、误报多
    - 基于协议：依赖RFC与现实中的应用的配置 - 建立常态协议边界
    - 基于流量：不正常流量，如DoS攻击
  - 规则型/启发型 —— 含AI专家系统/如规则(if-then)
- 响应
  - 被动：记录事件 + 通知 via 邮件/短信/弹窗/日志到中心NOC监控等 —— "被动IDS可用于检测FW有效性 by FW前后放置被动IDS > 比较告警结果
  - 主动：阻断（IPS） —— 修改ACL + 阻止某端口/源/协议流量 或 切断来源通信流量
- TLS卸载/代理/解密器（decryptor）
  - 演化：大部分通信来自HTTPS + IDPS无法识别加密流量 > 恶意攻击加密后 > IDPS
  - 流程：客户端 - FW | TLS解密器 - 外网 - 解密+监测 —— 劣：贵
  - 机制：部署出站口 - 拦截内外网TLS握手 - 生成两个HTTPS会话连接到TLS解密器端点
- 类型
  - 主机型HIDS/HIPS：监视单个主机的网络流量、系统进程、文件、注册表、日志、配置、用户行为、恶意软件（+反病毒软件）
    - 优：检测内部威胁、可定位具体文件、跟踪攻击进程
    - 劣：影响终端性能、日志在系统>被篡改、贵、非集中式管理、消耗系统资源
    - 防：签名和配置存在只读存储
  - 网络型NIDS/NIPS
    - 远程传感器收集关键节点数据 - 推送中央管理控制台SIEM
      - 优：通过RARP识别DNS查找攻击源
      - 劣：无法确定攻击是否成功/目标系统
    - 部署
      - 关键节点：路由器、FW、支持SPAN的交换机、网络分流器TAP
      - 带内in-band：流量必经之路 - 直接流量 —— 劣：单点故障可能
      - 带外out-band：交换机SPAN端口 - 只复流量副本 —— 劣：被动+无法阻止流量
    - 技术：协议分析、零拷贝、IP碎片/TCP报文重组、端口扫描 —— "零拷贝：一种I/O优化技术（Zero copy）
      - 应用：NIDS、Kafka、Nginx
      - 传统 —— 磁盘读取数据 -DMA拷贝- OS内核缓冲区 -CPU拷贝+read(一)- 用户空间缓冲区 -CPU拷贝+write(一)- 内核空间socket缓冲区 -DMA拷贝- 网卡缓冲区（4次拷贝+用户态/内核态切换 = 4次切换） —— "OS内核缓冲区：=磁盘高速缓存PageCache，内存中缓存最近被访问的磁盘数据
      - 改进 by 减少CPU调用 —— 磁盘读取数据 -DMA拷贝- OS内核缓冲区 -SG-DMA拷贝- 网卡缓冲区（2次切换2次拷贝）
        - OS内核缓冲区(=共享+用户空间缓冲区) CPU拷贝仅传输描述
        - + 网卡支持SG-DMA
        - 内存区域映射mmap()函数代替read（4次切换3次拷贝） —— sendfile()函数代替read&write（2次切换3次拷贝）
  - 应用层IDS：监测D+服务器之间特定应用程序的通信（特殊的NIDS）
  - 下一代入侵检测安全系统NDES：+AI 从网络审计日志提取信息
  - snort：轻量级开源IDS工具 - 流量分析,数据包记录

反恶意软件

- 杀毒软件 + 其它恶意代码 + 高级功能
- 部署：内外网边界 for 内容过滤的FW、电子邮件服务器、中央服务器统一推送更新至客户端 —— 注：一个OS最多一个 避免相干扰
- 类型
  - 特征型/签名检测：及时更新签名文件(库)+病毒特征码(DAT文件)（signature detection）
    - 产品：McAfee
    - 劣：不适用新病毒
  - 启发式/行为检测：可模拟计算机-逻辑/代码/结构 > 是否可疑行为（behavior detection）
    - 流程：发现可疑可执行文件 - 隔离+沙箱运行 - 分析内存CPU情况行为 - 加入黑名单-更新库
    - "沙箱/模拟器中区：仅允许可疑代码在特定环境中运行
    - 优：持续监控新病毒
  - 免疫：伪装文件已感染 —— 劣：太局限-只针对特定病毒
  - 基于信誉的保护：收集多个客户系统数据 - 把新识别 - 每个文件分配信誉值 - 下次识别用

终端保护与响应EDR

- 超越反恶意软件的高阶版 by 检测-记录-评估-响应 —— 与IT模式对了解互联网攻击 - 检测内存/文件/网络 - 隔离威胁
- 如：Open EDR、Bitdefender EDR、FortiEDR
- 衍生
  - 终端保护平台EPP：EDR变体 by PPDR模型 —— "Gartner P2DR模型：Predict-Prevent-Detect-Response —— 优：动态时间颗线、持续保护响应、多层防御
  - 托管检测和响应MDR：实时监控+专家响应 - 如：SIEM+网络流量分析NTA+EDR+IDS
  - 扩展检测和响应XDR：EDR + EPP + MDR

Enticement

诱惑

- 目的：拖延、收集攻击信息 > 防零日攻击
- 黑洞网络：合法IP+未被分配服务/主机 + 监测所有流量入 > 有流量=有恶意软件（Darknets）
- 蜜件：假装含敏感信息 + 实则过滤数据（honeyfiles）
- 蜜罐：作为诱饵的主机（honeypot）
  - 位于DMZ (内网+无法访问) —— 抉择：攻击后恢复
  - 类型
    - 低交互：蜜罐(Linux+模拟假服务+完全补丁) - netcat模拟假端口 - IDS - 外网 —— 黑客只能看 —— 可模拟FTP/Telnet/SMTP服务+监听部门木马
    - 中交互：蜜罐(Linux+模拟假服务+完全补丁) - honeyd.conf(模IOS+IP+拥护端口+配置ARP) - IDS - 外网 —— 黑客可以玩
    - 高交互：蜜罐(真实OS+真服务+真端口+无补丁) - IDS - 外网 —— 劣：被攻破作为跳板机
  - 黏性蜜罐：使用真IP模拟虚机 —— 需要攻击 - 响应接触 - 自动化连接超时 > 失败
  - 客户端蜜罐：手动/自动模仿用户在访问网站的过程事务 —— 如点击邮件链接 - 挡下它的攻击（honeyclients）
- 蜜网：≥2蜜罐网络+日志服务器+通信器 组成的模拟网络（honeynet）
- DNS沉洞："Attack'（sinkhole）
- 填充单元：与蜜罐类似，被IDS检测的自动转至单元(模拟环境+假数据) - 黑客不知道+无法执行操作
- 伪码/伪旗：OS中故意设计的漏洞 - 诱捕黑客（pseudo flaw）
- 法律风险：引诱 enticement vs 诱捕 entrapment(违法执法)

其它

- 垃圾邮件检测 —— 贝叶斯过滤：审查前面的事件来预测将来的事件 —— 对每个单词赋概率分析 - 使用数学公式 - 评估是否为垃圾邮件
- 过滤
  - 内容过滤器：检测文本 by 关键词匹配 - DPI
  - URL/Web过滤：检测FQDN、特定路径名、文件名、文件扩展名、整个URL
- 应用安全：如Windows应用控件默认 by GPO AppLocker - Allow/Deny、iOS仅允许从苹果store下载app、禁止运行删除改变的应用程序
- 警告栏：向授权用户和非授权用户告知组织的安全策略，如活动被审计 "禁止入内"类提示
- Web
  - HTTP会话管理 by
    - 确保会话ID的随机性、长度适当、带时间戳
    - Cookies
    - URL重写：截取请求 - 重定向至其它URL > 隐藏实际路径
    - 隐藏表单字段：不在前台显示 - 提交至后台服务器
    - 内建框架如Java HTTPSession
  - 参数限制 —— 1.登录失败3次 - 会话cookie"允许登录次数"从3变0 - 客户端锁定 - 中间人攻击-改次数500 + 密码暴力攻击
  - 网管接口管理
    - 删除管理接口、改用专有接口、+身份验证、限制IP地址访问
    - "网管
      - 带外管理：网管管理信息通过与业务网络不同的网络通道
      - 带内管理：网管数据与业务数据使用同一通道

Presented with xmind